

DATA RETENTION, DISPOSAL AND DISASTER RECOVERY POLICY

Version 1.1

Revision Date: August 28, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Data Retention, Disposal and Disaster Recovery Policy
Document ID	POL-DRD-001
Current Version	1.1
Approved Date	August 28, 2026
Approved By	Information Security Steering Committee
Effective Date	August 28, 2026
Next Review Date	August 28, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	POL-DRD-001 v1.0 (Data Retention and Disposal Policy)
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorised by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC6.5, CC7.5 and CC9.1, the Availability criteria A1.1 through A1.3, and GDPR Articles 5, 17 and 32(1)(c). The retention schedule and the recovery objectives register are the artifacts; this Policy is short by design.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE5

2 SCOPE5

3 ROLES AND DEFINITIONS.....5

4 TERMINOLOGY5

5 RETENTION7

6 LEGAL HOLD.....7

7 DISPOSAL7

8 BACKUP8

9 RECOVERY OBJECTIVES8

10 DISASTER RECOVERY.....9

11 RECOVERY TESTING.....9

12 RECORDS 10

13 EXCEPTIONS..... 10

14 REFERENCE..... 10

15 DOCUMENT POLICY HISTORY..... 10

1 Overview and Purpose

PromptHalo Technologies (“the Company”) keeps information for as long as it has a reason to and then disposes of it. This Policy says how that decision is made and how disposal is evidenced.

The retention periods themselves live in a schedule rather than in this document, so that a period can change without amending a policy.

It also says how the Company gets that information back when it is lost or the systems holding it are unavailable. Retention and recovery sit in one document because they are the same question asked in two directions: what has to survive, and for how long.

2 Scope

This Policy covers Company and client information wherever it is held, and any device or media that has held it.

It also covers the backup, restoration and recovery of the systems and services the Company depends on to hold that information and to deliver its service, including those operated by subservice organizations.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. The Accountable Party authorizes disposal of Confidential or Restricted information before it is carried out. [SOC 2: CC6.5]
5. The Accountable Party approves the recovery objectives, is the only person who may declare a disaster, and authorizes recovery. [SOC 2: CC7.5, A1.2]
6. The Security Officer maintains the recovery plans, runs the annual restoration test and recovery exercise, and reports the results to the Committee. [SOC 2: A1.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Backup** — a copy of information held separately from the system of record so that the information can be restored if the original is lost, corrupted or encrypted by an attacker.

- 34 3. **Business continuity** — keeping the Company able to serve its clients during a disruption, of
35 which technical recovery is one part.
- 36 4. **Confidential information** — information classified Confidential or Restricted under the Data
37 Classification Policy, including customer data.
- 38 5. **Control** — an activity, automated or manual, performed on a defined cadence that produces
39 evidence it occurred.
- 40 6. **Cryptographic erasure** — rendering information unrecoverable by destroying the keys that
41 protect it and recording that destruction.
- 42 7. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
- 43 8. **Disaster** — a disruption that ordinary incident response cannot resolve within the recovery time
44 objective of the affected system, and which the Accountable Party has declared as such.
- 45 9. **Information Security Steering Committee** — the Company's oversight body for information
46 security. At the Company's current size, the Committee comprises the CEO, and every reference
47 in this policy to a decision, approval, review or report of the Committee is satisfied by a dated
48 written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2,
49 CC1.3]
- 50 10. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of
51 the Company.
- 52 11. **Recovery point objective** — the maximum amount of data, expressed as a period of time, the
53 Company accepts losing for a given system.
- 54 12. **Recovery time objective** — the period within which a given system is to be restored to service
55 after a disruption is declared.
- 56 13. **Restoration test** — a restore of information from backup into an isolated environment, verified
57 against expected content and recorded.
- 58 14. **Retention schedule** — the record of how long each category of information is kept and on what
59 basis.
- 60 15. **Sanitization** — rendering information on media irrecoverable before the media leaves Company
61 control or is reused.
- 62 16. **Security Officer** — the individual accountable for day-to-day operation of the security program.
- 63 17. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that
64 requires risk reassessment.
- 65 18. **Subservice organization** — a third party whose controls the Company relies upon and which is
66 carved out of the Company's report.

5 Retention

1. Each category of information has a retention period and a basis — a client agreement, a legal requirement, or a Company decision — recorded in the retention schedule. [SOC 2: CC6.5 · GDPR Art. 5(1)(e)]
2. Client information is retained for the period the client agreement specifies and returned or deleted at the end of the engagement, with the action recorded. [SOC 2: CC6.5 · GDPR Art. 17]
3. Where information is subject to a deletion commitment, backups and snapshots holding it are identified and the retention that applies to them is stated honestly to the client rather than described as immediate. [SOC 2: CC6.5 · GDPR Art. 17]
4. The schedule is reviewed annually and whenever a client agreement introduces a different period. [SOC 2: CC6.5]

6 Legal Hold

A legal hold suspends disposal. It is short but it must exist, because the retention schedule otherwise deletes on time and that becomes the problem.

1. Where the Company becomes aware of actual or anticipated litigation, a regulatory investigation, or a client request to preserve, the Accountable Party places a hold on the information concerned. The hold names what is preserved, why, and who imposed it, and is recorded on the same day. [SOC 2: CC6.5, CC2.1]
2. Information under hold is not disposed of even where its retention period has expired, and automated deletion is suspended for it. The hold overrides the schedule until it is lifted. [SOC 2: CC6.5]
3. A hold is lifted in writing by the person who imposed it, and normal retention resumes from that point. Holds are reviewed at the annual retention review so that one does not persist by inertia. [SOC 2: CC6.5]

7 Disposal

Disposal of Confidential or Restricted information is authorized before it is carried out and recorded afterwards. [SOC 2: CC6.5]

1. Media and devices that have held Company or client information are sanitized or destroyed before disposal, reassignment or return, and the action is recorded. Because work happens in cloud services rather than on local disks, this arises rarely — which is the point. [SOC 2: CC6.5 · HIPAA §164.310(d)(2)]
2. Cloud storage disposal relies on the provider's deletion mechanisms, or on cryptographic erasure where the Company holds the keys, rather than on a physical process the Company does not perform. [SOC 2: CC6.5]

3. A disposal register records each action with its classification, retention basis and evidence, and holds any vendor destruction certificates. It is reconciled against the asset inventory so that an asset marked disposed is confirmed as gone. [SOC 2: CC6.5, CC2.1]

8 Backup

A backup that has never been restored is a hypothesis. This section says what is copied, where it is held, and how a failure is noticed before it matters.

1. Systems holding Company or client information are backed up on a defined schedule, and the scope, frequency and retention of each backup set are recorded. Anything not on that list is not backed up, which is a decision rather than an oversight. [SOC 2: A1.2 · GDPR Art. 32(1)(c)]
2. Backups are encrypted in transit and at rest to the standard the Encryption Policy sets, and access to them is restricted to the personnel who may access the source system. A backup is otherwise a copy of the data with the controls taken off. [SOC 2: A1.2, CC6.7]
3. Backups are held in an account, region or service separate from the system they protect, so that a single credential compromise or regional failure does not take both. [SOC 2: A1.2, CC6.6]
4. Backup jobs are monitored, and failures raise an alert that is resolved and recorded. A silent failure is otherwise discovered at restore time, which is the worst moment to discover it. [SOC 2: A1.2, CC7.2]
5. Backup retention follows the retention schedule, and where a deletion commitment applies, the backup persistence is stated to the client as Section 5 requires rather than described as immediate. [SOC 2: CC6.5 · GDPR Art. 17]

9 Recovery Objectives

1. Each in-scope system has a recovery time objective and a recovery point objective, recorded against that system in the recovery objectives register and approved by the Accountable Party. [SOC 2: A1.2, CC9.1]
2. Objectives are set at what the Company can demonstrate at a test, not at what it would like to achieve. Where a tested result does not meet the objective, either the objective or the architecture changes, and the decision is recorded. [SOC 2: A1.3]
3. The current objectives are [production service: RTO 24 hours, RPO 4 hours]; [corporate collaboration, email and file storage: RTO 48 hours, RPO 24 hours]; [source code and build pipeline: RTO 48 hours, RPO 24 hours]. They are confirmed at the annual review and whenever a significant change affects them. [SOC 2: A1.2]
4. Where a client agreement specifies a shorter objective, that agreement governs and the register records it against the client. [SOC 2: CC9.1, CC9.2]

10 Disaster Recovery

Most disruptions are incidents and are handled as incidents. A disaster is the case where that is not going to work in time, and someone has to say so out loud.

1. The Accountable Party declares a disaster. The declaration names the systems affected, the objective being worked to and who is leading recovery, and is recorded on the day it is made. [SOC 2: CC7.5, A1.2]
2. Recovery runs under the roles and communications the Incident Response Policy sets. Disaster recovery is an escalation of that process rather than a parallel one, so that one set of people runs one plan. [SOC 2: CC7.4, CC7.5]
3. Restoration follows the recovery plan for the affected system, which records the order of restoration, the dependencies between systems, and the access needed to carry it out. The plan and that access are held so that they remain reachable when the primary environment is not; a plan stored only inside the system it recovers is not a plan. [SOC 2: A1.2, CC7.5]
4. The Company relies on its cloud providers for infrastructure resilience. Those providers are subservice organizations, their availability commitments are recorded in the vendor file, and the Company sets its own objectives within those commitments rather than beyond them. [SOC 2: A1.2, CC9.2]
5. Clients and other affected parties are told under the notification matrix in the Incident Response Policy. Where the availability of personal data is affected, the obligations in the Privacy Policy apply as well. [SOC 2: CC2.3, CC7.5 • GDPR Art. 32(1)(c)]
6. Recovery closes when service is restored, data integrity is confirmed against the last known good state, and the Accountable Party records the closure with the time taken measured against the objective. [SOC 2: CC7.5, A1.3]

11 Recovery Testing

1. A restoration test is carried out at least annually for each in-scope system: information is restored from backup into an isolated environment and verified against expected content. An untested backup is treated as an untested backup. [SOC 2: A1.3]
2. A disaster recovery exercise is carried out at least annually and may be a tabletop. It works a declared scenario through the recovery plan and records the points at which the plan was wrong, which is the purpose of running it. [SOC 2: A1.3, CC7.5]
3. Each test records its date, scope, participants, the elapsed time against the objective, and any deficiency found. Deficiencies are tracked to closure under the Information Security Policy. [SOC 2: A1.3, CC4.2]
4. Recovery plans and objectives are reviewed after each test, after any declared disaster, and on any significant change. [SOC 2: A1.3, CC3.4]

12 Records

1. The retention schedule with periods and bases. [SOC 2: CC6.5]
2. The disposal registers with authorizations and evidence. [SOC 2: CC6.5]
3. Deletion confirmations at the end of engagements. [SOC 2: CC6.5]
4. The backup schedule and the record of backup job results. [SOC 2: A1.2]
5. The recovery objectives register, with its approvals. [SOC 2: A1.2, CC9.1]
6. The recovery plans for in-scope systems, with their version history. [SOC 2: A1.2]
7. Restoration test and recovery exercise results, with deficiencies and their closure. [SOC 2: A1.3]
8. Disaster declarations and their closure records. [SOC 2: CC7.5]

13 Exceptions

Where information cannot be disposed of when its period ends — a legal hold, or a backup that cannot be selectively purged — the position is recorded by the Accountable Party with the reason and a review date.

Where a system cannot meet its recovery objective — a dependency the Company does not control, or an architecture that a test has shown will not restore in time — the gap is recorded by the Accountable Party with the reason, the compensating measure and a review date, and the objective is not restated as though it were met.

14 Reference

1. SOC 2 Trust Services Criteria, Security category [CC2.1, CC6.5, CC7.4, CC7.5, CC9.1, CC9.2]
2. POL-DCL-001 Data Classification Policy [SOC 2: CC2.1]
3. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
4. POL-ENC-001 Encryption Policy [SOC 2: CC6.7]
5. POL-AM-001 Asset Management Policy [SOC 2: CC2.1]
6. EU General Data Protection Regulation, Articles 5, 17 and 32(1)(c)
7. SOC 2 Trust Services Criteria, Availability category [A1.1, A1.2, A1.3]
8. POL-IRP-001 Incident Response Policy [SOC 2: CC7.4, CC7.5]
9. POL-VM-001 Vendor Management Policy [SOC 2: CC9.2]
10. POL-RM-001 Risk Management Policy [SOC 2: CC3.2]

15 Document Policy History

Version	Date	Description
---------	------	-------------

Version	Date	Description
1.0	August 18, 2026	Initial policy release as Data Retention and Disposal Policy.
1.1	August 28, 2026	Retitled Data Retention, Disposal and Disaster Recovery Policy. Added Backup, Recovery Objectives, Disaster Recovery and Recovery Testing sections; supporting terminology, roles, records, exceptions and references. Availability criteria A1.1–A1.3 and CC7.5 brought into coverage.

198